ASSESSMENT TOOL III

Name	**B Akshaya**
Register Number	**192424336**
Date	**14.10.2026**

COURSE CODE: ITA1420

COURSE NAME: Ethical Hacking

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Activity Tool: Assignment (Low)
Assessment Tool Weightage: 10%

Code of Conduct:

I B Akshaya(192424336)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:Akshaya

Q.While testing a web application, you find a vulnerability that could allow you to access other clients' data hosted on the same shared server. This is outside your contracted scope. What do you do, and how does this scenario illustrate the limits of ethical hacking engagements?

RESPONSIBLE HANDLING OF AN
OUT-OF-SCOPE CROSS-TENANT VULNERABILITY



Conceptual diagram: shared hosting and tenant-isolation boundaries.

1.Objectives

The objectives of this assignment are:

1. To understand the importance of authorization and scope in ethical hacking.
2. To identify the risks associated with shared-server environments.
3. To explain how cross-tenant data exposure can occur.
4. To describe the correct response when an out-of-scope vulnerability is discovered.
5. To understand responsible disclosure and confidential evidence handling.
6. To recommend preventive security controls.
7. To explain the ethical and professional limits of penetration testing.

Central principle

Technical capability is not the same as authorization. A responsible tester reports the weakness without unnecessarily accessing, copying, or modifying third-party information.

2. Introduction to Ethical Hacking

Ethical hacking is an authorized security assessment intended to identify weaknesses before malicious actors exploit them. A tester may examine authentication, access control, session management, input validation, configuration, and other security controls. Unlike a criminal attacker, an ethical hacker must work within documented permission and agreed test conditions.A professional engagement usually defines the target assets, testing window, permitted techniques, excluded systems, emergency contacts, evidence-handling rules, and reporting process. These conditions reduce the possibility that testing will disrupt business operations or affect people who have not consented.

In this case, the tester is authorized to test a particular web application but discovers a possible route to other customers' data on the same shared server. The discovery is important, yet it does not automatically extend the tester's permission. The correct response is to stop before crossing the boundary, record only safe evidence, and notify the authorized contact.

Core ethical principles

Principle	Application in this scenario
Authorization	Test only assets and methods explicitly approved.
Confidentiality	Do not inspect or disclose other clients' information.
Least harm	Use the least intrusive validation possible.
Accountability	Document actions and report through the agreed channel.
Honesty	Separate observed evidence from possible impact.

3. Real-World Context: Multi-Tenant Hosting

Real-world analogy: a cloud hosting provider may operate a shared platform for many organizations. Customers can share physical infrastructure while expecting their accounts, databases, files, and application records to remain logically separated. A flaw in tenant authorization can violate that separation. The following case study is fictional but realistic. It is designed to demonstrate a common security principle; it is not a claim about a specific company or a confirmed real incident.

Case study: Northstar Retail Cloud (fictional)

Northstar Retail Cloud is a fictional software provider hosting online portals for several retailers. A security team is contracted by Retailer A to test only Retailer A's web portal. During testing with a test account supplied for Retailer A, the tester notices that a resource request may not be correctly checking which retailer owns the requested record. Because the platform hosts several retailers, a weak ownership check could potentially allow a user in Retailer A's environment to request records belonging to Retailer B. The tester has not been authorized to test Retailer B, and the tester must not open or download those records to prove the issue.

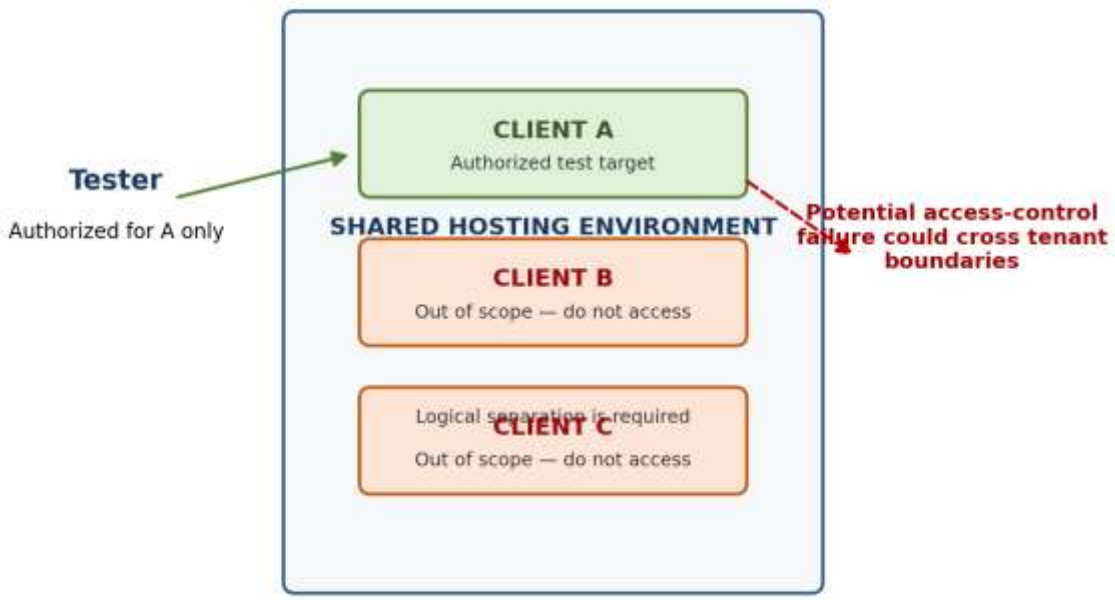


Figure 1. Conceptual multi-tenant hosting model and the scope boundary.

Why this is serious

- Customer records may include personal, commercial, order, or account information.
- The weakness may undermine tenant isolation across a shared service.
- Unnecessary testing could expose data and create a second security incident.
- The service owner needs prompt, accurate information to investigate and remediate.

4. Technical Explanation of the Vulnerability

A possible cause is broken access control. The application may authenticate a user correctly but fail to verify whether that user is authorized to access a specific record. An insecure direct object reference (IDOR) is one possible pattern: an application accepts an object identifier from a request but does not enforce ownership or permission on the server. The precise cause must be confirmed by the authorized system owner.

Authentication versus authorization

Concept	Question answered	Example
Authentication	Who are you?	The user successfully signs in.
Authorization	What may you access?	The server checks whether the user may read this retailer's order.
Tenant isolation	Which customer's resources belong to this tenant?	A Retailer A account cannot read Retailer B records.

Potential consequences

- Confidentiality loss if information is disclosed.
- Integrity loss if unauthorized changes are possible.
- Availability impact if records or functions can be disrupted.
- Contractual, regulatory, and reputational consequences for the provider.

A careful report must distinguish possibility from confirmed impact. If the tester has not accessed another client's records, the report should say that the issue may permit cross-tenant access and that the exposure scope has not yet been established.

5. Immediate Response: What I Would Do

Step 1 — Stop out-of-scope testing

I would stop any action that might access, alter, enumerate, or download another client's information. I would not continue simply because the application appears to permit it.

Step 2 — Recheck the rules of engagement

I would review the authorization letter, statement of work, target list, excluded systems, permitted methods, test window, and escalation contacts. If the scope is ambiguous, I would pause and ask the engagement lead for clarification rather than assume permission.

Step 3 — Preserve minimal safe evidence

I would record the in-scope endpoint, timestamp, test account, sanitized request/response, and the behavior that suggests an access-control failure. I would avoid collecting third-party data. If safe validation is impossible without crossing the boundary, I would stop without further exploitation.

Step 4 — Report promptly

I would notify the designated security contact or engagement manager using the agreed confidential channel. I would explain the possible impact, the evidence available, and the fact that no further cross-tenant access was attempted.

Step 5 — Wait for written approval

If more testing is needed, I would request a written scope expansion identifying approved assets, techniques, dates, data safeguards, and stop conditions. Relevant system owners or service providers may also need to authorize testing.

6. Responsible Response Flowchart



Figure 2. Decision workflow for handling a suspected out-of-scope vulnerability.

Decision table

Situation	Responsible decision	Reason
Other client data might be reachable	Stop before accessing it	The data is outside the agreed scope.
Scope wording is unclear	Pause and ask for written clarification	Ambiguity is not permission.
Evidence can be captured with test data	Capture minimal sanitized evidence	Supports triage while limiting harm.
Safe proof requires cross-tenant access	Do not proceed without approval	Third-party rights must be respected.
Issue appears urgent	Escalate through the incident process	Enables rapid risk management.

7. Evidence Handling and Responsible Disclosure

Evidence should help the owner reproduce and fix the vulnerability without creating unnecessary exposure. A useful report includes the affected in-scope endpoint, time of observation, test conditions, sanitized request and response, expected behavior, observed behavior, potential impact, and suggested remediation.

Evidence-handling checklist

- Use test accounts and synthetic records wherever possible.
- Remove personal information, credentials, session cookies, tokens, and secrets.
- Do not save bulk responses or records belonging to unrelated customers.
- Store evidence only in approved, access-controlled locations.
- Share the report only with authorized recipients.
- Follow the engagement's retention and deletion rules.

Example report summary

Title: Potential cross-tenant authorization weakness in shared retail platform.

Summary: During authorized testing of Retailer A's portal, a request pattern suggested that tenant ownership may not be consistently enforced. Retailers B and C are outside the current scope. Testing was stopped before attempting to retrieve or modify their records.

Potential impact: If confirmed, the issue could expose information across tenant boundaries. The actual extent of exposure is unknown and requires authorized investigation.

Recommended action: Review server-side authorization and tenant ownership checks, inspect relevant logs through the approved incident-response process, and perform controlled retesting after written authorization.

8. Limits of Ethical Hacking Engagements

8.1 Permission is specific

Permission to test one web application does not automatically cover the hosting provider, adjacent tenants, databases, APIs, or production systems. Authorization should identify the exact targets and permitted actions.

8.2 Access is not consent

A server response may reveal that a resource is reachable, but that does not mean the tester has a right to inspect it. Technical possibility and legitimate permission are separate questions.

8.3 Third parties have independent rights

Other customers may have separate agreements, confidentiality expectations, and legal protections. Their information must be protected even when a weakness makes it technically accessible.

8.4 The test must be proportionate

The objective is to provide enough reliable evidence to enable remediation, not to maximize the amount of data accessed. Broad enumeration, bulk downloading, destructive testing, and changes to live records may be unjustified and harmful.

8.5 A contract does not override every rule

Testing must also respect applicable law, privacy obligations, platform rules, and the rights of other organizations. Some work may require authorization from both the customer and the service provider.

8.6 Knowing when to stop is a professional skill

An ethical hacker is judged not only by the ability to discover a weakness, but also by restraint, communication, confidentiality, and responsible handling after discovery.

9. Risk Assessment and Remediation

A suspected cross-tenant weakness should be triaged promptly. The final severity depends on verified exploitability, the sensitivity and volume of potentially affected data, required privileges, exposure to attackers, and the possible impact on confidentiality, integrity, and availability.

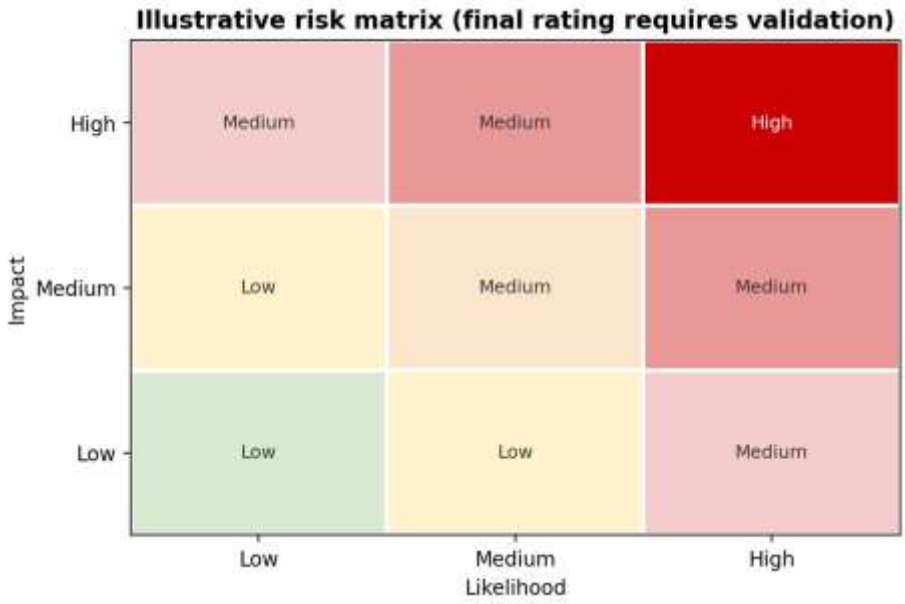


Figure 3. Illustrative risk matrix. The system owner should assign the final rating using verified evidence.

Recommended technical controls

Control	Purpose
Server-side object authorization	Verify permission for every read, update, and delete request.
Tenant-aware database queries	Filter resources using trusted tenant context.
Secure identifier handling	Never rely on hidden UI controls or unpredictable IDs alone.
Automated negative tests	Confirm Tenant A cannot read or change Tenant B records.
Monitoring and logging	Detect repeated authorization failures without logging sensitive content.
Controlled retesting	Validate the fix under documented authorization.

A temporary mitigation may be appropriate if the risk is urgent, but only authorized system owners should make production changes. The tester should recommend actions and follow the agreed escalation process rather than independently altering the live service.

10. Lessons Learned and Professional Reflection

Lessons for the tester

- Read the scope before testing and refer to it whenever a new asset appears.
- Treat third-party information as confidential, even if it is accidentally exposed.
- Use the least intrusive proof that establishes the security concern.
- Report facts clearly and avoid claiming data theft or compromise without evidence.
- Seek written approval before expanded testing and document all decisions.

Lessons for the organization

- Define scope, exclusions, escalation contacts, and emergency procedures clearly.
- Ensure contracts explain how out-of-scope critical findings should be reported.
- Build tenant ownership checks into every server-side data access path.
- Provide a safe test environment and synthetic data for validation.
- Coordinate remediation and retesting with all necessary system owners.

Professional reflection

This scenario shows that ethical hacking is a disciplined, permission-based activity. The tester must balance the need to establish a real security risk with the obligation to protect people and organizations that did not authorize the test. Responsible restraint is not a failure to investigate; it is part of doing security work correctly.

Principle	Application
Authorization	Stay within the approved scope
Confidentiality	Protect other clients' information
Least harm	Avoid unnecessary access and disruption
Accountability	Document and report findings
Honesty	Report only supported conclusions
Proportionality	Collect minimum necessary evidence
Professionalism	Obtain approval before further testing

These ethical principles are essential for conducting responsible and professional penetration testing. Authorization ensures that testing is performed only on approved systems and within the agreed scope. Confidentiality protects sensitive information belonging to clients and other organizations. The principle of least harm requires testers to avoid unnecessary access, data exposure, or system disruption. Accountability ensures that all findings and testing activities are properly documented and reported. Honesty requires the tester to present accurate evidence without exaggerating the impact of a vulnerability. Proportionality ensures that only the minimum evidence necessary is collected, while professionalism requires written approval before any additional testing is performed.

11. Conclusion

If I discovered a vulnerability that could expose other clients' data on a shared server, I would stop testing at the edge of my authorization, avoid accessing or copying third-party data, preserve only minimal sanitized evidence, and report the finding promptly through the approved channel. I would request written authorization and an updated scope before any additional cross-tenant testing.

The scenario illustrates the limits of ethical hacking because authorization is specific and bounded. A tester may be technically capable of reaching connected systems, but that capability does not grant permission to explore them. The purpose of ethical hacking is to improve security while respecting confidentiality, consent, applicable law, and the rights of all affected parties.

If I discovered a vulnerability that could expose other clients' data on a shared server, I would immediately stop testing beyond the authorized scope. I would not access, download, or modify other clients' information. Instead, I would preserve minimal sanitized evidence, review the rules of engagement, and promptly report the issue through the approved confidential channel.

If additional testing were necessary, I would obtain written authorization and an updated scope before proceeding. I would also recommend appropriate remediation, including server-side authorization checks, tenant isolation, secure logging, and controlled retesting.This scenario illustrates the limits of ethical hacking engagements because permission is specific and bounded. An ethical hacker must understand not only how to discover vulnerabilities, but also when to stop, how to protect third-party data, and how to report risks responsibly.

Key takeaway

> **Discovering a vulnerability creates a responsibility to report it safely—not a right to access everything it might expose.**

12. References

1. National Institute of Standards and Technology (NIST), Technical Guide to Information Security Testing and Assessment, SP 800-115. https://csrc.nist.gov/pubs/sp/800/115/final
2. OWASP Foundation, Web Security Testing Guide. https://owasp.org/www-project-web-security-testing-guide/
3. OWASP Foundation, Authorization Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html
4. OWASP Foundation, Insecure Direct Object Reference Prevention Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand